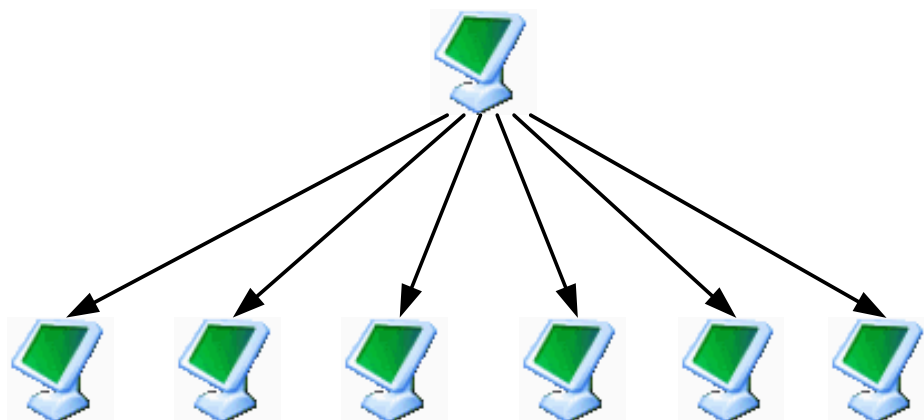


บทที่ 7

การสแกนเพื่อตรวจสอบ

7.1 Network Ping Sweeps



รูปที่ 7-1 แสดงการทำงานของ *ping sweep*

หนึ่งในเทคนิคพื้นฐานที่นิยมกระทำกันก็คือ การ ping ไปยังเครื่องเป้าหมายจำนวนมากพร้อมๆ กัน ในลักษณะคล้ายกับการกวาดหรือกราดยิง ซึ่งเราเรียกว่าการทำ ping sweep เพื่อตรวจสอบว่าเครื่องปลายทางใดบ้างที่ยังเปิดทำงานอยู่ โดยปกติ ถ้าคุณใช้คำสั่ง ping ธรรมดา, ping จะมีการส่ง แพ็กเก็ต ICMP ECHO (Type 8) ออกไปยังเครื่องปลายทางและรอคอย ICMP ECHO_REPLY (Type 0) ที่ถูกส่งกลับมา ถึงแม้ ping จะมีประโยชน์สำหรับการทดสอบว่าเครื่องปลายทางเปิดอยู่หรือไม่ก็ตาม แต่มันจะเหมาะสมสำหรับเครื่องที่อยู่บนเน็ตเวิร์กขนาดเล็กถึงขนาดกลางเท่านั้น มันจะไม่มีประสิทธิภาพเพียงพอที่จะนำมาใช้ตรวจสอบเครื่องที่อยู่บนเน็ตเวิร์กขนาดใหญ่ได้ การตรวจสอบเครื่องที่อยู่ในเน็ตเวิร์กที่ใช้แอดเดรสในคลาส A อาจกินเวลานานหลายชั่วโมงกว่าจะทราบผล เทคนิคในการ ping sweep มีหลายเทคนิคแตกต่างกันไป เช่น ปกติแล้วการ ping จะรอคอยการตอบสนองจากเครื่องทีละเครื่อง ก่อนจะไปทดสอบเครื่องอื่นๆ ถัดไป มันจะใช้การส่ง แพ็กเก็ต ICMP ออกไปพร้อมๆ กันแบบขนานไปยังเครื่องปลายทางหลายๆ เครื่อง ในลักษณะคล้าย “Round Robin” (คือส่งแพ็กเก็ต ICMP ไปที่เครื่อง 1,2,3,... ถึงเครื่องสุดท้าย แล้ววนกลับมาส่งแพ็กเก็ตไปที่เครื่อง 1,2,3 ใหม่ไปเรื่อยๆ แล้ววนกลับมาอีก โดยไม่จำเป็นต้องหยุดรอจากตอบสนองจากเครื่องแรก) ดังนั้น จะทำงานได้รวดเร็วกว่าคำสั่ง ping ธรรมดามาก แต่อาจทำให้เกิดทราฟฟิกจำนวนมากที่เกิดขึ้นอาจเข้าไปรบกวนแบนด์วิธของ WAN Link ความเร็วอย่างต่ำเช่น 128K ISDN หรือ เฟรมรีเลย์ (Frame relay)

แต่ในบางครั้งจะอย่างไรถ้าที่เน็ตเวิร์คเป้าหมายได้มีการบล็อกห้ามแพ็กเก็ต ICMP ไว้ไม่ให้เข้าถึงเน็ตเวิร์คภายในได้

ถ้าแพ็กเก็ต ICMP ถูกบล็อกเอาไว้ เรามีเทคนิคและเครื่องมืออื่นที่ใช้ตรวจสอบได้ว่าเครื่องปลายทางใดบ้างที่เข้าถึงได้และเปิดทำงานอยู่ แต่อย่างไรก็ตาม มันอาจไม่ถูกต้องและรวดเร็วเท่ากับตรวจสอบด้วย ping sweep

เทคนิคที่ว่ามันก็คือ การสแกนพอร์ต นั่นเอง ซึ่งเป็นเทคนิคแรกที่ใช้ถ้าใช้ปลายทางบล็อกแพ็กเก็ต ICMP ไว้ โดยการสแกนพอร์ตต่างๆไปบนแต่ละเครื่องเราจะสามารถคาดการณ์ได้ว่าเครื่องไหนเปิดอยู่บ้าง เทคนิคนี้ค่อนข้างกินเวลาและอาจไม่สามารถสรุปแน่ชัดได้ TCP Ping Scan ด้วย TCP Ping scan ไปที่พอร์ตที่ต้องการส่วนมากจะเป็นพอร์ต 80 เนื่องจากเป็นพอร์ตมาตรฐานที่เราเตอร์หรือไฟร์วอลล์ของไซต์ส่วนใหญ่จะเปิดไว้ให้ผ่านเข้าไปได้ยังเว็บเซิร์ฟเวอร์ที่มักตั้งอยู่ในส่วนที่เรียกว่า Demilitarized zone (DMZ) หรือยิ่งไปกว่านั้น อาจทะลุผ่านเข้าไปในอินทราเน็ตภายในด้วย โดยจะทำงานดังนี้คือสร้างแพ็กเก็ตของโปรโตคอล TCP ซึ่งได้เซตแฟล็ก ACK (Acknowledge) ไว้เป็น 1 ด้วย (ต่อไปเราจะเรียกแพ็กเก็ตลักษณะนี้สั้นๆว่า แพ็กเก็ต TCP ACK) แล้วส่งแพ็กเก็ตเหล่านี้ไปยังเน็ตเวิร์คเป้าหมายปลายทางหรือไม่ ถ้ามีก็แสดงว่าเครื่องปลายทางสามารถติดต่อได้และเปิดทำงานอยู่ แพ็กเก็ต TCP ACK นี้มักวิ่งทะลุผ่านไฟร์วอลล์ที่ไม่ค่อยฉลาดนักหรือคอนฟิกไว้ไม่ดีพอให้เข้าไปได้

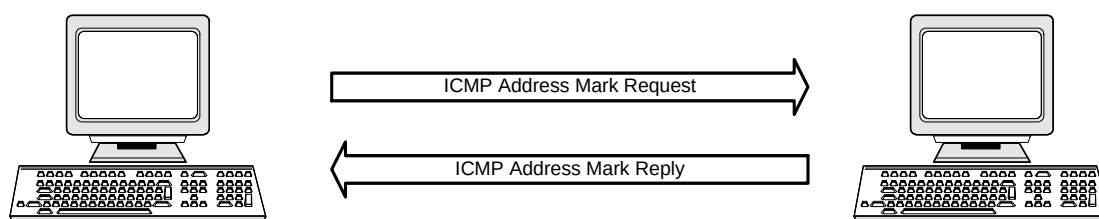
อย่างที่ได้เห็นไปแล้วว่าเทคนิคนี้ค่อนข้างใช้ได้ผลถึงแม้ใช้ปลายทางจะบล็อกแพ็กเก็ต ICMP ไว้ ซึ่งถ้า พอร์ต 80 ใช้ไม่ได้อาจใช้เป็นพอร์ตมาตรฐานที่มักพบบ่อย อย่างเช่น พอร์ตของเซิร์ฟเวอร์ SMTP (หมายเลข 25), POP (110), AUTH (113), IMAP (143) หรือพอร์ตอื่นๆ ที่เป็นไปได้

ถ้าพอร์ตที่เครื่องปลายทางได้เปิดไว้แพ็กเก็ตของโปรโตคอล TCP ที่มีการเซตแฟล็ก SYN(S bit) ไว้และแพ็กเก็ต TCP ที่มีการเซตแฟล็ก ACK ไว้จะถูกส่งกลับมา

นอกจากนี้ยังมีเทคนิคอื่นในการที่จะตรวจสอบว่าเครื่องปลายทางยังเปิดทำงานอยู่หรือไม่ด้วยการส่งแพ็กเก็ต ICMP ECHO ออกไป พร้อมทั้งแพ็กเก็ตของโปรโตคอล ICMP ใน Type อื่นๆด้วย ได้แก่ ICMP Type TIME STAMP REQUEST และ ICMP INFO request เพื่อที่ว่า ถึงแม้แพ็กเก็ต ICMP ใน Type ECHO ถูกสกัดกั้นไว้ที่เราเตอร์ตัวที่เชื่อมต่อออกอินเทอร์เน็ตหรือที่ไฟร์วอลล์ก็ตาม แต่โอกาสที่แพ็กเก็ต ICMP ใน Type อื่นๆจะวิ่งทะลุผ่านเข้าไปเพื่อตรวจสอบได้ก็ยังมีอยู่ หรืออาจจะส่งไปด้วยแพ็กเก็ตปลอม (spoofed packet) เพื่อป้องกันการตรวจสอบย้อนกลับได้ว่าแพ็กเก็ตถูกส่งมาจากที่ไหน

กล่าวโดยสรุป ขั้นตอนนี้จะทำให้เราสามารถตรวจสอบได้อย่างแท้จริงว่าเครื่องปลายทางใดบ้างที่เราสามารถติดต่อได้โดยตรงผ่านอินเทอร์เน็ต ด้วยการส่งแพ็กเก็ต ICMP ใน TYPE ต่างๆ หรือใช้เทคนิคของการสแกนพอร์ตเข้าไปตรวจสอบ จากลิสต์รายการหมายเลข IP Address ที่อยู่ในคลาส C จำนวนกว่า 200 หมายเลข เราสามารถตรวจสอบได้ว่าแท้จริงแล้วมีเครื่องไหนบ้างที่อยู่ในขอบข่ายของการเป็นเครื่องเป้าหมายได้ เพื่อช่วยลดโอกาสของการตรวจสอบให้แคบลงและประหยัดเวลามากขึ้น

7.2 ICMP Queries



รูปที่ 7-2 แสดงการทำงานของ ICMP QUERY

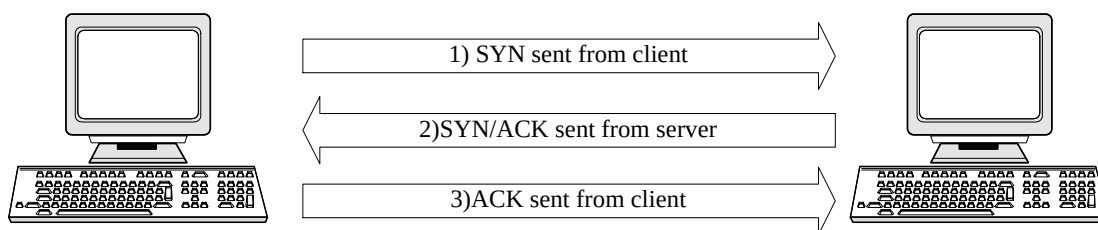
คือการส่งแพ็กเก็ตของโปรโตคอล ICMP ไปสอบถาม ตัวอย่างเช่น สอบถามเวลาของเครื่องปลายทาง (เพื่อดูว่าเครื่องนั้นอยู่ในโซนเวลา (time zone) แอปใด) ด้วยการส่งแพ็กเก็ต ICMP type TIMESTAMP, สอบถามค่าของ Subnet Mask ของเครื่องปลายทางด้วยการส่งแพ็กเก็ต ICMP type ADDRESS MASK REQUEST Subnet Mask เป็นค่าที่สำคัญพอสมควรเพราะมันจะทำให้คุณทราบหมายเลข Subnet Address ของเครื่องเน็ตเวิร์คเป้าหมาย การทราบค่าของ Subnet Address จะช่วยให้เราสามารถโฟกัสไปที่เน็ตเวิร์คที่ต้องการได้และหลีกเลี่ยงการส่งข้อมูลโดยระบุแอดเดรสปลายทางเป็น Broadcast Address

7.3 Port Scanning

การสแกนพอร์ตหรือ Port Scanning เป็นกระบวนการในการคอนเน็กเข้าไปที่ TCP Port หรือ UDP Port ของเครื่องปลายทางเพื่อค้นหาว่ามีเซิร์ฟเวอร์อะไรบ้างที่ทำงานอยู่หรืออยู่ในสถานะ LISTENING

การค้นหาพอร์ตที่เปิดอยู่เป็นเรื่องสำคัญทีเดียวในการตรวจสอบประเภทของระบบปฏิบัติการและแอปพลิเคชันที่ใช้งานอยู่ในระบบ เพราะ ระบบปฏิบัติการหรือเซิร์ฟเวอร์ที่รันอยู่อาจมีข้อบกพร่องบางอย่างที่อนุญาตให้ผู้ใช้ที่ไม่ได้ผ่านการตรวจสอบเข้าไปในระบบได้ หรือมีข้อบกพร่องเกี่ยวกับระบบการรักษาความปลอดภัยที่เป็นที่รู้จักกันดี โดยเฉพาะเซิร์ฟเวอร์บางเวอร์ชันที่ยังไม่สมบูรณ์ เครื่องมือและเทคนิคในการสแกนพอร์ตได้รับการพัฒนาอย่างต่อเนื่องมาหลายปี เทคนิคการสแกนพอร์ตที่เรากล่าวไปข้างต้นนั้น เป็นเพียงการสแกนพอร์ตเพื่อรู้ว่าเครื่องปลายทางเปิดอยู่และติดต่อผ่านทางอินเทอร์เน็ตหรือเครือข่ายได้หรือไม่ เท่านั้น แต่สำหรับเทคนิคการสแกนพอร์ตที่จะกล่าวถึงถัดไป เป็นการสแกนพอร์ตเพื่อค้นหาว่ามีพอร์ตหมายเลขใดเปิดอยู่ที่เครื่องปลายทางนั้นบ้าง

- TCP connect scan เป็นการคอนเน็กไปที่พอร์ตที่ต้องการบนเครื่องปลายทาง แล้วขอเปิดคอนเน็กชันของโพรโทคอล TCP ด้วยกลไกมาตรฐานที่เรียกว่า TCP three-way handshake (SYN, SYN/ACK และ ACK) แต่วิธีนี้มักถูกตรวจจับได้โดยง่ายโดยไฟร์วอลล์ที่ไซต์ปลายทาง



รูปที่ 7-3 TCP 's 3-way handshake

รูปแสดงการเปิดคอนเน็กชันของโพรโทคอล TCP จะอาศัยกลไก three way handshake โดยขั้นแรกจะส่งแพ็กเก็ต TCP ที่เซตแฟล็ก SYN เป็น 1 ให้ออกไปที่เครื่องปลายทาง ขั้นที่สอง เครื่องต้นทางจะได้รับ TCP SYN/ACK กลับมาและขั้นสุดท้าย จะส่งแพ็กเก็ต TCP ACK กลับไปอีกครั้งเพื่อยืนยันว่าได้รับแพ็กเก็ตในขั้นที่สองแล้ว

- TCP SYN scan เทคนิคนี้บางครั้งเรียกว่า half-open scanning สาเหตุเพราะว่า คอนเน็กชันที่สมบูรณ์ของโพรโทคอล TCP ยังไม่ได้ถูกเปิดขึ้น เพราะเมื่อแพ็กเก็ต TCP ที่เซตค่าแฟล็ก SYN และ ACK ไว้เป็น 1 (TCP SYN/ACK) นั้นก็เพียงพอแล้วที่จะสรุปว่า พอร์ทดังกล่าวอยู่ในสถานะ LISTENING แต่ถ้าพอร์ทดังกล่าวไม่ได้เปิดอยู่ แพ็กเก็ต TCP ที่เซตค่าแฟล็ก RST และ ACK ไว้เป็น 1 (TCP RST/ACK) จะถูกส่งกลับมาแทน เทคนิคค่อนข้างน่าใช้กว่าเทคนิคแรกเพราะส่วนใหญ่แล้วไฟร์วอลล์ที่ไซต์ปลายทางมักตรวจจับได้ค่อนข้างยาก
- TCP FIN scan เทคนิคนี้จะส่งแพ็กเก็ต TCP ที่เซตค่าแฟล็ก FIN เป็น 1 (TCP FIN) ไปยังพอร์ตที่ต้องการ ถ้าไดร์เวอร์ของโพรโทคอล TCP/IP ที่เครื่องปลายทางได้ถูกพัฒนาขึ้นมา โดยมีฟีเจอร์ตามในมาตรฐาน RFC หมายเลข 739 ครบถ้วน (<http://www.ietf.org/rfc/rfc0793.txt>) เครื่องปลายทางจะส่งแพ็กเก็ต TCP RST ของทุกๆพอร์ตที่ปิดอยู่กลับมาให้ (กล่าวง่าย ๆ ก็คือ เราจะทราบหมายเลขพอร์ตที่ไม่ได้เปิดให้บริการ) โดยปกติแล้ว เทคนิคนี้มักใช้ได้กับเครื่องปลายทางที่รันยูนิกซ์
- TCP Xmas Tree scan เทคนิคนี้จะส่งแพ็กเก็ต TCP ที่เซตแฟล็ก FIN ,URG และ PUSH ไปยังพอร์ตเป้าหมายที่เครื่องปลายทาง และอาศัยมาตรฐาน RFC 739 อีกเช่นกัน เครื่องปลายทางจะส่งแพ็กเก็ต TCP RST ของทุกพอร์ตที่ปิดอยู่กลับมาให้

- TCP Null scan เทคนิคนี้จะส่งแพ็กเก็ต TCP ออกไปโดยเซตค่าของทุกๆฟิลด์ให้เป็น 0หมด และ อาศัยมาตรฐาน RFC 793 อีกเช่นกัน เครื่องปลายทางจะส่งแพ็กเก็ต TCP RST ของทุกๆพอร์ตที่ปิดอยู่กลับมาให้
- TCP ACK scan เทคนิคนี้จะถูกใช้เพื่อค้นหา “rule” และ “policy” ต่างๆที่เซตไว้ที่ไฟร์วอลล์ เพื่อตรวจสอบดูว่าไฟร์วอลล์นั้นๆทำหน้าที่แค่เพียงกรองแพ็กเก็ตได้อย่างง่าย ๆ หรือเป็นไฟร์วอลล์ที่มีความฉลาดพอสมควรและใช้เทคนิคการกรองแพ็กเก็ตขั้นสูง
- TCP Window scan เทคนิคนี้จะตรวจสอบพอร์ตที่เปิดอยู่ รวมทั้งตรวจสอบว่า พอร์ตใดบ้างที่ถูกฟิลเตอร์เอาไว้ไม่ให้ผ่านเข้าไปถึง และพอร์ตหมายเลขใดได้รับการอนุญาตไว้บ้าง โดยอาศัยช่องโหว่จากความผิดปกติบางอย่างในการแจ้งค่าของ TCP Window Size ของโพรโตคอล TCP/IP
- TCP RPC scan เทคนิคนี้ใช้งานได้เฉพาะกับเครื่องปลายทางที่รันยูนิกซ์เท่านั้น มันถูกใช้เพื่อตรวจสอบดูว่ามีเซอร์วิสใดทำงานอยู่บนเซอร์วิส RPC บ้าง รวมทั้งตรวจสอบเวอร์ชันของเซอร์วิสนั้นและโปรแกรมอื่นที่เกี่ยวข้อง
- UDP scan เทคนิคนี้จะส่งแพ็กเก็ตของโพรโตคอล UDP ไปยังพอร์ตเป้าหมาย ถ้าเครื่องปลายทางตอบกลับมาด้วยแพ็กเก็ต ICMP type PORT UNREACHABLE นั้นหมายความว่าพอร์ตนั้นปิดอยู่ในทางตรงกันข้าม ถ้าเราไม่ได้รับแพ็กเก็ต ICMP type ดังกล่าว เราสามารถสรุปได้ว่าพอร์ตนั้นเปิดอยู่ เนื่องจากโพรโตคอล UDP เป็นโพรโตคอลลักษณะ connectionless คือไม่รับรองว่าแพ็กเก็ตที่ส่งไปจะถึงเครื่องปลายทางครบถ้วนหรือไม่ ดังนั้นความถูกต้องของผลลัพธ์ที่ได้จากเทคนิคนี้ก็อาจขึ้นกับปัจจัยอื่นๆ ด้วยเช่น ปริมาณทราฟฟิกในเน็ตเวิร์กและทรัพยากรบนเครื่องปลายทาง นอกจากนั้นมันยังเป็นเทคนิคที่ค่อนข้างช้าอีกด้วยถ้าคุณกำลังสแกนเน็ตเวิร์กที่ใช้งานไฟร์วอลล์หรือเราเตอร์ที่มีการฟิลเตอร์กรองแพ็กเก็ต จึงขอให้เตรียมใจไว้ด้วยกับผลลัพธ์ที่ไม่คาดคิดของ UDP scan

ไดเรกทอรีของโพรโตคอล TCP/IP ของระบบปฏิบัติการบางตัวอาจส่งแพ็กเก็ต TCP RST กลับไปยังเครื่องต้นทางตลอดไม่ว่าพอร์ตๆ นั้นจะเปิดหรือปิดอยู่ ดังนั้นจึงเป็นไปได้ว่า ผลลัพธ์ที่ได้ อาจแตกต่างกันไปไม่แน่นอน แต่อย่างไรก็ดี การตรวจสอบด้วยแพ็กเก็ต TCP SYN ธรรมดา นั้นจะทำงานได้ดีสำหรับทุกๆ โฮสต์

7.4 การตรวจหาประเภทของระบบปฏิบัติการ

จุดประสงค์ประการแรกของการสแกนคือ การค้นหา TCP port และ UDP port ที่เปิดอยู่บนเครื่องปลายทาง ส่วนจุดประสงค์ประการที่สองคือ การค้นหาประเภทของระบบปฏิบัติการที่รันอยู่บนเครื่องปลายทาง ประเภทของระบบปฏิบัติการที่เราทราบจะถูกนำไปใช้ประโยชน์ในขั้นตอนการค้นหารายละเอียดต่างๆ (enumeration) โดยอาศัยข้อบกพร่องต่างๆ ที่แต่ละระบบปฏิบัติการนั้นมี ดังนั้นเราจึงต้องมั่นใจว่า ระบบปฏิบัติการที่เราทราบนั้นเป็นข้อมูลที่ถูกต้อง

Active Stack Fingerprinting

Stack fingerprinting เป็นเทคโนโลยีที่ช่วยทำให้มั่นใจได้ว่าประเภทของระบบปฏิบัติการที่ค้นหาได้นั้นเป็นระบบปฏิบัติการที่ถูกต้อง มีเปอร์เซ็นต์ความน่าเชื่อถือสูง โดยอาศัยหลักการที่ว่า ผู้ผลิตระบบปฏิบัติการแต่ละรายมักพัฒนาไดรเวอร์ของโพรโตคอล TCP/IP และเซิร์ฟเวอร์ที่ทำงานบนโพรโตคอล TCP/IP ให้มีเอกลักษณ์เฉพาะตัวเป็นของตัวเอง ซึ่งมักแตกต่างกับของระบบปฏิบัติการอื่น

ดังนั้น โดยการตรวจวัดความแตกต่างเหล่านี้ เราจะสามารถเริ่มคาดเดาได้อย่างมีเหตุผล แต่เพื่อให้มีความน่าเชื่อถือสูงสุด Stack fingerprinting จำเป็นต้องอาศัยการคอนเน็กไปพอร์ตที่เปิดอยู่อย่างน้อยหนึ่งพอร์ต แต่การทำงานของโครงการนี้ สามารถคาดเดาได้อย่างมีเหตุผล ถึงแม้ว่าจะไม่ได้คอนเน็กไปที่พอร์ตใดเลย แต่ผลที่ได้ก็อาจยังไม่น่าเชื่อถือนัก โดยให้สำรวจวิธีการตรวจวัดความแตกต่างกันที่ละวิธี

- Fin probe ใช้การส่งแพ็กเก็ตของโพรโตคอล TCP โดยเซตแฟล็ก Fin ให้เป็น 1 ไว้ ตามมาตรฐาน RFC 793 ระบุไว้ว่า พฤติกรรมที่ถูกต้องจะต้องไม่มีการส่งแพ็กเก็ตอะไรตอบสนองกลับไป แต่ทว่า ไดรเวอร์ของโพรโตคอล TCP/IP ในระบบปฏิบัติการบางตัว อย่างเช่น วินโดวส์เอ็นที จะตอบสนองกลับมาด้วยแพ็กเก็ตของโพรโตคอล TCP ที่เซตแฟล็ก Fin และ ACK ให้เป็น 1 ซึ่งเครื่องมือส่วนมากได้นำเทคนิคนี้ไปใช้กัน
- Bogus Flag probe ใช้การส่งแพ็กเก็ตของโพรโตคอล TCP โดยเซตแฟล็ก SYN ให้เป็น 1 พร้อมทั้งเซตบิตตำแหน่งที่ยังไม่ได้ใช้งานให้เป็น 1 ด้วย บางระบบปฏิบัติการเช่น ลินุกซ์ จะตอบสนองกลับมาด้วยการเซตแฟล็กบางตัวในแพ็กเก็ต ว่ามักเป็นค่าอะไร อย่างไรก็ตามบางระบบปฏิบัติการจะทำการ reset connection เมื่อได้รับแพ็กเก็ตนี้
- TCP Initial Sequence Number (ISN) sampling ใช้วิธีการตรวจหาแพทเทิร์นของ Sequence number ที่อยู่ในส่วนหัวของแพ็กเก็ตที่ได้รับการตอบสนองต่อการร้องขอการเชื่อมต่อ ว่าเป็นค่าอะไร ซึ่งสามารถแบ่งได้หลายกลุ่มเช่น ถ้าเป็นแบบ traditional 64K จะพบใน UNIX รุ่นเก่า, แบบ Random increments จะพบใน Solaris, IRIX, FreeBSD, Digital UNIX, Cray ในเวอร์ชันใหม่, แบบ True "random" จะพบใน Linux 2.0.*, OpenVMS, AIX เวอร์ชันใหม่, ส่วน Windows จะเป็นแบบ "time dependent" model คือค่าของ ISN จะเพิ่มขึ้นจำนวนหนึ่งที่กำหนดไว้ในแต่ละช่วงเวลา, และในบางครั้งจะใช้ค่า ISN ค่าเดียวไม่เปลี่ยนแปลง เช่นใน 3Com hubs จะใช้เป็น 0x803 ตลอดและใน Apple LaserWriter printers จะใช้เป็น 0xC7001
- "Don't fragment bit" monitoring บางระบบปฏิบัติการได้เซตบิต "Don't fragment bit" ไว้เพื่อเพิ่มความเร็วในการส่งข้อมูล ให้มอดีเตอร์บิตนี้เพื่อตรวจดูว่าระบบปฏิบัติการไหนเซตบิตนี้บ้าง
- TCP initial window size ใช้วิธีดูขนาดของ TCP window เพราะบางระบบปฏิบัติการจะมีการลือค่าไว้เลยว่าขนาดของ TCP window เป็นเท่าไร (เช่น AIX เป็นเพียงระบบปฏิบัติการเดียว

ที่มีขนาดของ window เท่ากับ 0x3F25 ส่วน window NT มีขนาด 0x402E) ค่านี้มักเป็นค่าเฉพาะตัวของแต่ละระบบปฏิบัติการด้วย จึงยังทำให้ผลที่ได้มีความถูกต้องมากขึ้น

- ACK value ระบบปฏิบัติการแต่ละระบบมักเซตค่าในฟิลด์ ACK ไม่เหมือนกัน บางระบบเซตค่าฟิลด์ ACK ให้สอดคล้องตามค่าของฟิลด์ SYN ที่เซตไว้ในฝั่งผู้ส่ง บางระบบจะเซตค่าฟิลด์ ACK ให้บวกจากค่าของฟิลด์ SYN ไปอีกหนึ่ง
- ICMP error message quenching บางระบบปฏิบัติการอาจปฏิบัติตามมาตรฐาน RFC 1812 และมีการจำกัดอัตราการส่งข้อความแจ้งข้อผิดพลาด ดังนั้น (ใน Linux kernel จะจำกัดการส่งข้อความแจ้งข้อผิดพลาดไปยังปลายทางที่อัตรา 80 แพ็กเก็ตต่อ 4 ± 0.25 วินาที) โดยการส่ง
- แพ็กเก็ตของโพรโทคอล UDP ไปยังหมายเลขพอร์ตสูงๆ แล้วค่อยนับจำนวนของ ICMP type PORT UNREACHABLE Message ที่ตอบกลับมาภายในช่วงเวลาที่กำหนด
- ICMP message quoting เมื่อพบข้อผิดพลาดเกี่ยวกับโพรโทคอล TCP/IP ระบบปฏิบัติการแต่ละประเภทจะให้ข้อมูลและสาเหตุต่าง ๆ มาในแพ็กเก็ตของ ICMP ไม่เท่ากัน บางระบบจะให้รายละเอียดมากบางระบบจะให้รายละเอียดน้อย (ใน Solaris จะส่งกลับมา a bit more และใน Linux จะส่งกลับมา even more than that) ดังนั้นโดยการสำรวจข้อมูลที่ได้มานี้ เราพอจะใช้ในการคาดเดาประเภทของระบบปฏิบัติการได้
- ICMP error message-echoing integrity บางระบบปฏิบัติการอาจดัดแปลงส่วนหัวของแพ็กเก็ต IP เมื่อมีการส่ง ICMP error message ด้วยการตรวจสอบลักษณะของการดัดแปลงดังกล่าวนี้คุณสามารถนำมาใช้ในการคาดเดาได้
- Type of service (TOS) ให้คุณสำรวจฟิลด์ที่ชื่อ Type of service ที่อยู่ในแพ็กเก็ต ICMP ประเภท port unreachable ซึ่งโดยปกติหลายระบบปฏิบัติการจะใช้ค่าศูนย์ แต่บางระบบอาจใช้ค่าอื่น เช่น Linux ใช้ 0xC0
- Fragmentation handling แต่ละระบบปฏิบัติการจะจัดการกับแพ็กเก็ตที่ถูกแฟรกเมนต์หรือหั่นซอยไม่เหมือนกัน เมื่อมีการประกอบแพ็กเก็ตย่อยขึ้นมาเป็นแพ็กเก็ตที่สมบูรณ์ บางระบบจะเขียนทับ
แพ็กเก็ตย่อยอันเก่าด้วยแพ็กเก็ตย่อยอันใหม่หรือบางระบบก็ทำในทางตรงกันข้าม โดยการสังเกตพฤติกรรมตรงนี้ เราพอจะใช้ในการคาดเดาประเภทของระบบปฏิบัติการได้เช่นเดียวกัน สามารถหาข้อมูลเพิ่มเติมได้ที่ www.secnet.com
- TCP options ได้ถูกกำหนดไว้ในมาตรฐาน RFC 793 และได้รับการปรับปรุงในมาตรฐาน RFC 1323 ในปัจจุบัน ผู้ผลิตหลายรายได้มีการอิมพลีเมนต์ออปชันพิเศษที่อยู่ใน RFC 1323 ไว้ในระบบปฏิบัติการของตน ดังนั้น ด้วยการส่งแพ็กเก็ตที่เซตออปชันหลายๆออปชันไปทดสอบอย่างเช่น no operation, maximum segment size, window scale factor และ timestamps มันเป็นไปได้ที่เราจะตั้งสมมติฐานเกี่ยวกับระบบปฏิบัติการที่รันที่เครื่องเป้าหมาย

ยกตัวอย่าง

Window Scale=10; NOP; Max Segment Size = 265; Timestamp; End of Ops;

บางระบบปฏิบัติการ เช่น FreeBSD จะ support ทุกอปชั่นข้างต้นขณะที่ Linux 2.0.X จะ support บางอปชั่น Linux 2.1.x support ทุกอปชั่น

แม้ว่าหลายระบบปฏิบัติการจะ support ออปชั่นเดียวกันแต่บางที่เราสามารถแยกแยะได้โดยจาก ออปชั่น the_values_of เช่น ถ้าส่งค่า MSS เล็กๆไปที่ Linux โดยทั่วไปแล้วมันจะส่ง MSS echo กลับไป ส่วนระบบปฏิบัติการอื่นจะส่งค่าที่แตกต่างกันกลับไป แต่ถ้ายังได้ผลลัพธ์เหมือนกันอีกก็สังเกตลำดับของอปชั่นที่ได้รับมา เช่น Solaris จะเป็น 'NNTNWME' ซึ่งหมายความว่า <no op><no op><timestamp><no op><window scale><echoed MSS> ขณะที่ Linux 2.1.122 จะเป็น MENNTNW ซึ่งจะเห็นได้ว่าเป็นอปชั่นเดียวกัน ส่ง MSS echo เหมือนกัน แต่ลำดับที่ส่งมาไม่เหมือนกัน

- SYN Flood Resistance บางระบบปฏิบัติการจะไม่ยอมรับการ connection ครั้งใหม่ ถ้ามีการส่งแพ็กเก็ต SYN ไปมากเกินไป ซึ่งหลายระบบปฏิบัติการนั้นสามารถที่จะจัดการกับแพ็กเก็ตที่ส่งเข้ามาได้ไม่เกินครั้งละ 8 แพ็กเก็ต แต่ใน kernel ของ Linux รุ่นใหม่มีวิธีการป้องกันปัญหานี้เช่น การใช้ SYN cookies ดังนั้นเราก็สามารถรู้ได้ว่าเป็นระบบปฏิบัติการอะไรโดยการส่งแพ็กเก็ตไป 8 แพ็กเก็ตไปยังพอร์ตที่เปิดอยู่แล้วดูว่าสามารถ connect ไปยังพอร์ตนั้นได้หรือไม่

7.5 ตัวอย่างเครื่องมือที่ใช้ในการสำรวจระบบเครือข่าย

Pinger จากบริษัท Rhino9 โปรแกรมตัวนี้ทำงานโดยจะส่งแพ็กเก็ต ICMP ECHO ออกไปพร้อมๆ กันแบบขนานในลักษณะของ Round robin และรอคอยการตอบสนอง นอกจากนั้น Pinger ยังอนุญาตให้คุณค้นหาชื่อโฮสต์และบันทึกผลลัพธ์ที่ได้ลงในไฟล์ด้วย ส่วนเครื่องมือที่เป็นผลิตภัณฑ์ทางการค้าอีกตัวหนึ่งซึ่งทำงานได้รวดเร็วพอกๆ กับ Fping หรืออาจจะเร็วกว่าด้วย ก็คือเครื่องมือจากบริษัท SolarWinds สาเหตุที่มันทำงานได้เร็วกว่าก็เพราะว่า มันอนุญาตให้กำหนดช่วงเวลาการรอคอย ระหว่างการส่งแพ็กเก็ต ICMP แต่ละครั้งด้วย ถ้าระบุ delay time ให้เป็น 0 หรือ 1 คุณสามารถสแกน IP Address ที่อยู่ในคลาส C พร้อมทั้งแปลง IP Address เป็นชื่อโฮสต์ได้ในเวลาน้อยกว่า 7 วินาที

Network Mapper (nmap) โดย Fyodor นอกจาก NMAP จะให้ทั้งความสามารถพื้นฐานในการสแกนต่างๆที่ได้กล่าวไปข้างต้นทั้งหมด ซึ่งค่อนข้างหายากเหมือนกันสำหรับเครื่องมือตัวเดียวแต่ให้ครอบคลุมทุกเทคนิค